

credential_scan

credential_scan.sh — git-hook credential-leak guard

Revision: 1 Last modified: 2026-06-16T18:30:00Z

Overview

scripts/git_hooks/credential_scan.sh is the shared scanner behind the project's local pre-commit and pre-push git hooks. It implements the §11.4.10.A clause 5 mandate to catch **inline secret-shaped literals** mechanically — the class that .gitignore (which only covers secret *files*) cannot stop. It is the §11.4.75 Layer-1 (pre-commit) and Layer-3 (pre-push) credential guard.

Forensic origin: an SSH password literal (WhiteSnake<REDACTED-§11.4.10>) reached the tracked tree across 20 text occurrences AND 6 compiled binaries because no commit/push-time grep existed (see docs/qa/secret_scrub_20260616T143748Z/PLAN.md).

Prerequisites

- bash, git, grep, perl on PATH.

Usage

```
# Install the hooks (idempotent):  
bash scripts/install_git_hooks.sh  
  
# Scan staged content (what pre-commit runs):  
bash scripts/git_hooks/credential_scan.sh --staged  
  
# Scan specific working-tree files (what pre-push runs per changed  
  file):  
bash scripts/git_hooks/credential_scan.sh path/to/file.sh
```

Exit 0 = clean; exit 1 = a credential-shaped literal was found (file:line printed, value MASKED — the scanner never prints the secret).

Pattern set (closed; extend deliberately)

1. Historical leaked-class token shape `WhiteSnake<digits>`.
2. Inline `-password[= ]"?<literal>` where the value is NOT `${VAR}` / `$env(VAR)` / empty / a `<redacted...>` marker / a placeholder.
3. `*_PASS/*_PASSWORD/Password: = "<literal>"` with a non-env, non-empty value.
4. Common provider API-key shapes: `sk-...`, `AKIA...`, `ghp_...`, `xox[baprs]-...`.

Edge cases / honest boundaries

- Env-ref values (`${SSH_WORKER_PASSWORD}`, `$env(SSH_WORKER_PASSWORD)`) `PASS` — they are the sanctioned scrub form.
- `constitution/`, `scripts/git_hooks/`, this doc, and `docs/qa/secret_scrub_*` are ignore-listed because they legitimately document the pattern class / token NAME.
- The scanner catches the enumerated shapes, NOT every conceivable secret encoding (e.g. base64-wrapped blobs). It is one strong layer, not a guarantee of zero leaks.

Related scripts

- `scripts/git_hooks/pre-commit`, `scripts/git_hooks/pre-push` — the hook entry points.
- `scripts/install_git_hooks.sh` — idempotent installer.

Last verified

2026-06-16 — anti-bluff: scanner FAILs on a planted `-password WhiteSnake<REDACTED-§11.4.10>` line and PASSes on the env-ref `-password "${SSH_WORKER_PASSWORD}"` form (mutation pair).